

CAHIER DES CHARGES

Messagerie privée · Éphémère · Chiffrée

ÉDITION DU 9 NOVEMBRE 2026 · VERSION 1.0 · PROJET OPEN

SOMMAIRE

Architecture du document

00 Synthèse de cadrage 3

01 Vision, objectifs et périmètre 3

02 Personas, parcours et rôles 4

03 Compte, identité et découverte 5

04 Cœur métier : cycle de vie des messages 5

05 Alertes des messages non lus 6

06 Messagerie et échanges de contenus 7

07 Appels, géolocalisation et proximité 8

08 Transformation vocale et filtres vidéo 8

09 Confidentialité et contrôles utilisateur 9

10 Identité visuelle et UX/UI 9

11 Écrans et structure de navigation 10

12 Architecture technique de référence 11

13 Modèle minimal de données 12

14 Événements, états et algorithmes 13

15 Sécurité, vie privée et conformité 14

16 Exigences non fonctionnelles 14

17 Plan de réalisation et livrables 15

18 Recette fonctionnelle et cas critiques 16

19 Risques, arbitrages et questions ouvertes 17

20 Références techniques et juridiques 17

21 Validation du cadrage 18

00 Synthèse de cadrage

Document de référence de conception - exigences confirmées, propositions d'implémentation et décisions restant à arbitrer.

GhOst est une application Android de messagerie privée, conçue pour privilégier le pseudonymat, le chiffrement de bout en bout, la conservation minimale et l'effacement automatique des échanges. Elle s'inscrit dans l'écosystème Open et adopte une identité visuelle monochrome, gris argent, inspirée des interfaces Liquid Glass.

> **EXIGENCE NON NÉGOCIABLE**
>
> La disparition effective dans l'application est déterminée par la plus proche de deux échéances : (1) la limite absolue de 24 heures après envoi ; (2) l'option d'expiration déclenchée par la première lecture. Un message non lu expire aussi à 24 heures.

Décision confirmée	Spécification
Nom	GhOst (G et O majuscules) ; appellation oGhost abandonnée.
Plateforme initiale	Android ; intégration conceptuelle à l'écosystème Open.
Identité	Pseudo / nom d'utilisateur et identifiant numérique ; pas de téléphone ni e-mail obligatoires.
Expiration après lecture	À la lecture ; 15 minutes ; 24 heures (et jamais après envoi + 24 h).
Rappels des non-lus	12 h, 3 h, 1 h, 15 min avant la limite absolue ; silencieux et confidentiels.
Interface	Liquid Glass gris / graphite / argent, animations fluides, ergonomie iOS adaptée à Android.

Lecture de ce document

- **OBLIGATOIRE (P0)** : indispensable au MVP et à la promesse de confidentialité.
- **PRIORITAIRE (P1)** : intégration dans la première version publique si validée techniquement.
- **ÉVOLUTIF (P2)** : version ultérieure, après mesure de coût, performance et risques.
- Les choix techniques et objectifs chiffrés proposés ne constituent pas des fonctions déjà développées ni auditées.

01 Vision, objectifs et périmètre

1.1 Vision produit

Permettre des conversations textuelles, vocales, vidéo et multimédias privées, accessibles au moyen d'une identité numérique pseudonyme, sans archives centrales permanentes des messages. La confidentialité doit provenir de l'architecture et des contrôles cryptographiques, non d'une simple absence d'affichage des données.

1.2 Objectifs

- Réduire au strict nécessaire les données de comptes, de messages et de présence.

- Assurer un chiffrement de bout en bout pour les contenus des conversations.
- Donner à l'expéditeur le choix de la durée après lecture, tout en imposant une limite de 24 h après l'envoi.
- Conserver l'expérience de communication en temps réel et le traitement des destinataires momentanément hors ligne.
- Offrir une esthétique premium, fluide, accessible et adaptée aux capacités du téléphone.

1.3 Inclus / exclu

Dans le périmètre	Hors périmètre initial
Inscription pseudonyme, messagerie 1:1, pièces jointes chiffrées, temporisation, rappels, découverte par ID.	Fil d'actualité public, publicités ciblées, historique illimité, sauvegarde des messages dans le cloud.
Appels, localisation temporaire et filtres vocaux/vidéo selon feuille de route.	Anonymat absolu, impossibilité garantie de capture, fonctionnement mondial fiable sans aucun serveur.

02 Personas, parcours et rôles

2.1 Rôles

Rôle	Droits et limites
Utilisateur	Créer et récupérer son compte, rechercher des contacts, envoyer / lire des messages, gérer ses réglages, bloquer / signaler.
Administrateur technique	Superviser la santé des services, les capacités, les abus et les incidents sans accéder au contenu chiffré.
Opérateur d'infrastructure	Administrer les relais, la disponibilité et les mécanismes de purge, selon permissions minimales et journalisation contrôlée.

2.2 Parcours principal

- Installation → création d'un pseudo et génération d'un identifiant aléatoire → création locale des clés → affichage de la phrase de récupération.
- Recherche exacte d'un utilisateur par pseudo ou identifiant → demande de conversation → vérification optionnelle des empreintes / QR code.
- Sélection de la durée après lecture → envoi chiffré → réception → première ouverture → expiration au plus tôt de deux échéances.
- Avertissements discrets avant la limite absolue si le message reste non lu → purge / masquage lorsque la limite est atteinte.

2.3 Principes de consentement

Toute utilisation de caméra, microphone, position, carnet d'adresses et notifications doit passer par une permission explicite pertinente. La recherche par localisation et le partage de coordonnées sont désactivés par défaut.

03 Compte, identité et découverte

3.1 Enregistrement et récupération - P0

- Pseudo affiché, nom d'utilisateur unique (politique de caractères à définir), identifiant numérique aléatoire non séquentiel.
- Génération des clés cryptographiques sur l'appareil ; les clés privées ne sont jamais transmises au serveur.
- Une phrase de récupération ou solution de transfert d'appareil, avec information claire sur le risque de perte d'accès.
- Un pseudo peut être modifié ; l'identifiant technique reste stable sauf recréation du compte.
- Absence de numéro de téléphone, e-mail ou nom civil obligatoires.

3.2 Recherche / contacts - P0

- Recherche par ID exact ou pseudo ; aucune indexation publique des contacts sans consentement.
- Protection contre l'énumération massive : limitations de requêtes, anti-abus, options d'invisibilité.
- Blocage, refus d'invitations, listes de confiance, demandes de messages provenant d'inconnus.
- QR code de mise en relation et empreinte cryptographique pour vérifier l'identité du correspondant.

3.3 Données de compte réellement nécessaires

Un service fonctionnel exige plus qu'un pseudo et un numéro : clés publiques / préclés, états de révocation, paramètres de routage limités et éventuellement jetons de notifications. Leur présence, leur base légale éventuelle et leur durée de conservation doivent être documentées. Aucune donnée secrète de récupération ne doit être conservée en clair côté serveur. [S1, S2, S8]

04 Cœur métier : cycle de vie des messages

4.1 Modes d'expiration approuvés

Mode	Déclencheur	Règle de suppression
À la lecture	Première ouverture / consultation	Supprimer à la fermeture de la première consultation ; empêcher toute réouverture.
15 min après lecture	Première lecture horodatée	Expire 15 minutes après la première lecture, au plus tard à l'envoi + 24 h.
24 h après lecture	Première lecture horodatée	Expire 24 h après la lecture, mais la limite envoi + 24 h prévaut.
Non lu	Aucune lecture	Expire exactement à l'échéance absolue : envoi + 24 h.

RÈGLE DE CALCUL

> Date limite = min(date d'envoi + 24 heures, date de première lecture + délai choisi). Tant qu'aucune lecture n'a eu lieu, seule la date d'envoi + 24 heures s'applique. Le mode « À la lecture » prend effet à la fin de la première consultation.

Conséquence : le choix « 24 h après lecture » ne peut jamais prolonger la vie du message au-delà de 24 h après envoi ; dans la pratique, c'est donc généralement le plafond absolu qui provoque sa disparition.

4.2 Exemple vérifiable



Un message envoyé à 08 h, ouvert à 10 h, réglé sur 15 minutes après lecture, expire à 10 h 15. Le même message non lu expire à 08 h le lendemain. S'il est ouvert à 07 h 55 le lendemain, il expire à 08 h, et non à 08 h 10.

4.3 Événement de lecture et règle de concurrence

- « Lu » = première ouverture effective de l'élément par le destinataire ; le timestamp est unique et ne se réinitialise jamais.
- La durée sélectionnée est attachée au message au moment de son envoi et ne change pas rétroactivement.
- Les opérations concurrentes de lecture / suppression doivent être idempotentes ; aucune restauration après expiration.
- L'expiration empêche immédiatement l'accès et le déchiffrement dans l'application, même si la purge physique locale attend le réveil du système.

05 Alertes des messages non lus

5.1 Rappels validés - P0

Le destinataire reçoit, lorsqu'il y est autorisé et techniquement possible, des alertes relatives aux messages non lus avant l'expiration absolue. Les rappels sont **silencieux** (ni son ni vibration générés par l'application) et **confidentiels** (sans nom, pseudo, aperçu, texte ni pièce jointe).

Temps restant	Heure depuis envoi	Exemple de texte neutre
12 heures	T + 12 h	Vous avez un message non lu qui expirera dans 12 h.
3 heures	T + 21 h	Un message non lu expire dans 3 h.
1 heure	T + 23 h	Un message non lu expire dans 1 h.
15 minutes	T + 23 h 45	Dernier rappel : un message expire dans 15 min.

5.2 Logique des rappels

- Annuler les rappels restants dès la première lecture, dès l'expiration ou en cas de blocage / retrait.
- Si la livraison survient après une ou plusieurs étapes, ne pas rejouer les rappels déjà échus ; n'afficher que les alertes futures utiles.
- Regrouper les rappels pour réduire les notifications et éviter d'exposer le nombre exact de messages sur écran verrouillé si le mode discret le demande.
- Prévoir une désactivation utilisateur ; les quatre seuils sont activés par défaut dans la configuration retenue.
- Notifications locales quand disponibles ; notification push distante portant uniquement une indication opaque, sans contenu privé.

5.3 Limites Android

Les restrictions d'arrière-plan, le mode économie d'énergie, les autorisations de notification et la disponibilité réseau peuvent décaler ou empêcher l'affichage des rappels. Les alarmes exactes doivent être utilisées seulement lorsque les règles Android le permettent. L'expiration logique ne doit pas dépendre de la réception effective des alertes. [S5]

06 Messagerie et échanges de contenus

6.1 Messagerie individuelle - P0

- Envoi/réception de texte, emojis, réponses contextuelles, suppression locale, demandes de contact et indicateurs d'état non intrusifs.
- Accusés de réception et de lecture optionnels ; le mécanisme de première lecture reste indispensable au minuteur local, même si l'accusé visible est désactivé.
- Liste de conversations temporaire ; pas d'historique permanent, pas de moteur de recherche sur anciennes conversations expirées.
- Prévisualisation de contenu désactivée par défaut dans les notifications, widgets et journaux applicatifs.

6.2 Médias et fichiers - P1

- Formats : MP3, MP4, PDF, PNG, JPEG, notes vocales et fichiers supplémentaires autorisés via politique MIME.
- Chiffrement côté émetteur avant transfert ; validation du type, limite de taille configurable et protection contre les fichiers malveillants.
- Le média suit la même règle de double expiration que le message qui le contient.
- Pour les médias « À la lecture », toute première ouverture compte comme consultation : la sortie du lecteur clôt la possibilité de réouverture.
- Nettoyage des aperçus, miniatures, caches, fichiers temporaires, index multimédias et ressources cloud.

6.3 Groupes privés - P1

Groupes sur invitation, rôles de modération, contrôle d'entrée, messages chiffrés, politiques de durée par message, suppression liée à chaque destinataire ; synchronisation et gestion de l'état de groupe à concevoir. MLS (RFC 9420) constitue un standard candidat à évaluer pour les groupes. [S3]

07 Appels, géolocalisation et proximité

7.1 Voix et vidéo - P1

- Appels audio et vidéo 1:1 chiffrés, contrôle micro / caméra, fin d'appel, qualité adaptative et options réseau dégradé.
- WebRTC et mécanismes ICE / STUN / TURN pour la mise en relation ; TURN relaie le média lorsque l'accès direct n'est pas possible. [S4]
- Ne conserver ni enregistrement d'appel ni flux média côté serveur par défaut ; journaux techniques minimaux à durée bornée.
- Appels de groupe en phase ultérieure, après choix de topologie (SFU, E2EE de bout en bout) et validation des coûts.

7.2 Géolocalisation volontaire - P1

- Partager une position ponctuelle ou une position temporaire avec un destinataire choisi.
- Permission géographique explicite, indication visible du partage actif et interruption à tout moment.
- Pas de carte de localisation des personnes par défaut ; découverte de proximité uniquement sur activation volontaire.
- Positions chiffrées et soumises à la double expiration absolue des messages.

7.3 Transfert hors Internet - P2

Évaluer un transfert local entre téléphones proches, compatible avec les capacités Android et des mécanismes de découverte authentifiés. Ce mode ne doit pas être annoncé comme une messagerie mondiale sans infrastructure ; la portée et les compatibilités restent à vérifier en prototype.

08 Transformation vocale et filtres vidéo

8.1 Modificateur de voix - P2

- Notes vocales : choix de préréglages (grave, aiguë, robotique, synthétique), aperçu local, validation puis envoi.
- Appels audio / vidéo : modification en temps réel en amont du chiffrement, avec réglage d'intensité et bouton de désactivation immédiate.
- Traitement local prioritaire, sans transmission de voix brute à des services tiers ; mesure de latence, CPU, batterie et qualité.
- Prévoir des protections contre l'usurpation de voix et une information claire aux interlocuteurs selon le contexte légal.

8.2 Filtres d'appels vidéo - P2

- Floutage du visage / arrière-plan, avatars et masques graphiques, effets légers à faible consommation.
- Filtres désactivables ; chute automatique vers vidéo standard si le matériel ne suit pas.
- Aucun catalogue de filtres ne doit rendre le microphone, la caméra ou le chiffrement moins sûrs.

CRITÈRE D'INTÉGRATION

> Aucun engagement de « temps réel fluide » avant mesures sur plusieurs appareils Android représentatifs. Les performances des transformations audio / vidéo relèvent d'un prototype spécifique.

09 Confidentialité et contrôles utilisateur

Fonction	Priorité	Spécification
Mode Fantôme	P1	Masquer présence, dernière activité et confirmations visibles ; ne pas promettre l'invisibilité réseau.
Cercle de confiance	P1	Limiter la réception de messages aux personnes approuvées.
Profil invisible	P1	Exclusion des recherches non exactes et des fonctions de découverte.
Verrouillage	P0	Code / biométrie selon capacités Android ; verrouillage à la reprise.
Effacement d'urgence	P1	Effacement volontaire des données locales et clés, avec étape anti-déclenchement accidentel.
Identités secondaires	P2	Pseudonymes contextuels et clés de séparation ; politiques anti-abus.
Alertes discrètes	P0	Aucun nom / contenu dans les notifications ; mode silencieux.
Blocage / signalement	P0	Blocage simple, protection du destinataire, signalement volontaire sans accès généralisé au contenu.

Limites explicites

Un destinataire peut photographier un écran, utiliser un appareil compromis ou copier des données hors de GhOst. L'application doit réduire les risques de sauvegardes et de captures lorsque le système le permet, sans promettre une destruction universelle ni l'impossibilité de capture. Les adresses IP et métadonnées réseau peuvent être visibles selon le chemin de transport.

10 Identité visuelle et UX/UI

10.1 Logo validé

Le logo sélectionné met en scène un fantôme argenté translucide dans une bulle de discussion, avec le nom **GhOst**, sur un fond gris anthracite à effet de verre. C'est l'actif graphique de référence fourni dans le projet.



10.2 Système de couleurs (proposition fonctionnelle)

Jeton	Hexadécimal	Usage
Graphite profond	#15191F	Fonds sombres, panneaux, écrans de confidentialité.
Ardoise	#30343C	Cartes translucides, élévation.
Gris acier	#929AA5	Contours, composants neutres.
Argent glacé	#E6E9EE	Surface claire, reflets et éléments actifs.
Blanc	#FFFFFF	Texte et contraste sur fond sombre.

10.3 Principes de design

- Surfaces « Liquid Glass » : translucidité mesurée, flous locaux, reflets subtils, profondeur sans surcharges.
- Graphisme monochrome par défaut ; pas de bleu vif, couleurs de statut réservées aux éléments nécessitant un signal visuel.
- Transitions légères, barres de navigation flottantes, gestes naturels, retour haptique facultatif et polices lisibles.
- Deux thèmes : clair et sombre, plus sélection automatique par réglage système.
- Mode réduire les animations, respect des tailles de texte, contrastes accessibles et variante sans flou pour appareils modestes.

11 Écrans et structure de navigation

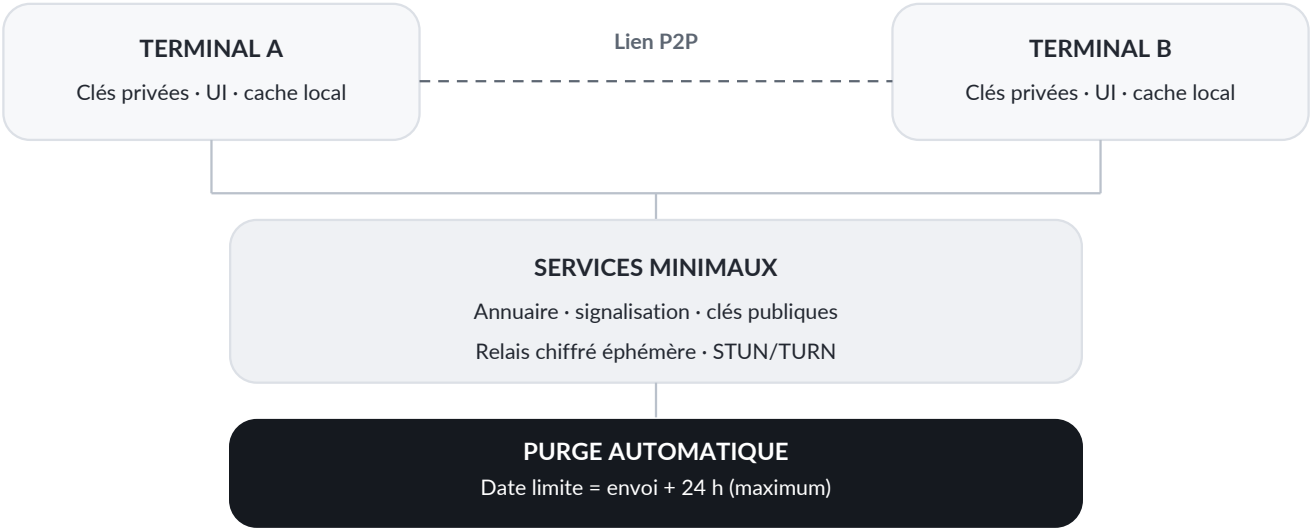
Écran	Contenu essentiel	Priorité
Accueil / onboarding	Proposition de valeur, confidentialité, débuter, langues, permissions progressives.	P0
Création de compte	Pseudo, ID numérique, phrase de récupération, génération de clés.	P0
Conversations	Liste de discussions, messages non lus, durée restante, nouvelle conversation.	P0

Écran	Contenu essentiel	Priorité
Chat	Bulles, durée choisie, état de lecture, envoi de fichiers et notes vocales.	P0
Recherche / contacts	Pseudo / ID, invitations, QR code, blocage.	P0
Alertes / échéances	Récapitulatif discret des messages non lus proches de l'expiration.	P0
Appels	Historique local éphémère, appels audio / vidéo, contrôles de confidentialité.	P1
Profil / paramètres	Identité, modes discrets, notifications, appareil, sécurité, données.	P0
Groupe	Invitations, participants, permissions, règles d'échanges.	P1
Studio vocal / vidéo	Effets, prévisualisation, qualité, permissions.	P2

Navigation principale

Barre inférieure suggérée : **Discussions · Appels · Contacts · Réglages**. L'outil de recherche doit rester accessible depuis Discussions et Contacts. Chaque conversation présente le temps restant calculé localement et non une promesse d'horodatage visible côté serveur.

12 Architecture technique de référence



Architecture hybride : le P2P est recherché lorsqu'il est viable, tandis que les services minimaux assurent signalisation, annuaire, préclés et distribution des messages chiffrés. En cas de connectivité bloquante, un relais assure la transmission. Les serveurs ne disposent pas des clés permettant de lire les messages. [S1, S2, S4]

12.1 Pile initiale envisagée

Domaine	Choix de départ	Observation
Android natif	Kotlin + Jetpack Compose	Cible de développement proposée ; variante faible GPU.
Messages 1:1	Protocole E2EE audité inspiré de PQXDH + Double Ratchet	Évaluer bibliothèques, compatibilité et licences. [S1, S2]
Appels / P2P	WebRTC + STUN/TURN	Plan média audio / vidéo, connexions et repli relayé. [S4]
Backend minimal	Go ou Rust ; API authentifiée	Choix final après prototype / expertise équipe.
Annuaire	Base minimale de comptes et clés publiques	Aucune conservation d'historique de messages en clair.
En attente / fichiers	File éphémère chiffrée + stockage objet TTL	Suppression / refus d'accès à l'échéance de 24 h.
Notifications	FCM avec notifications sans charge utile sensible	Ne pas considérer FCM comme E2EE natif. [S6]

13 Modèle minimal de données

Les entités ci-dessous sont des structures conceptuelles, non le schéma SQL définitif. Toute valeur persistante doit avoir une finalité, un contrôle d'accès et une durée de conservation explicites.

Entité	Attributs strictement nécessaires	Rétention
Account	account_id numérique, handle, display_name, created_at, state	Vie du compte / suppression à la clôture.
Device / Keys	device_id, identity_public_key, signed_prekeys, version, revocation	Durée de validité technique ; rotation / révocation.
MessageEnvelope	opaque_msg_id, dest_device, ciphertext, sent_at, absolute_expires_at	Jusqu'à livraison ou au plus tard 24 h.
Attachment	object_id opaque, ciphertext, media_type, expiry, integrity_hash	Au plus tard 24 h ; suppression anticipée possible.
NotificationRoute	token de livraison, device, préférences non sensibles	Durée utile ; révocation / rotation.
Block / request	Identifiants bloqués / invitations nécessaires	Jusqu'au changement par l'utilisateur.

Entité	Attributs strictement nécessaires	Rétention
SecurityTelemetry	Indicateurs agrégés / pseudonymisés	Durée courte documentée, sans contenu ni destinataire lisible.

Règle de non-rétention

Interdiction de stocker les messages déchiffrés, médias originaux non chiffrés, secrets privés et prévisualisations privées sur les serveurs. Les journaux et sauvegardes doivent exclure les contenus, minimiser les identifiants et être dotés de politiques d'effacement. Les restaurations de bases ne doivent pas ressusciter des enveloppes expirées.

14 Événements, états et algorithmes

14.1 États d'un message

CRÉÉ → CHIFFRÉ → ENVOYÉ → (EN_ATTENTE / LIVRÉ) → OUVERT (facultatif) → EXPIRÉ → PURGÉ. Les états « EXPIRÉ » et « PURGÉ » sont terminaux : aucune réapparition par synchronisation ou restauration.

14.2 Algorithme contractuel

```
A = sent_at + 24h
if first_read_at is absent:
   expiry_at = A
elif mode == "ONCE":
   expiry_at = min(A, first_view_closed_at)
elif mode == "15_MIN":
   expiry_at = min(A, first_read_at + 15min)
elif mode == "24_H":
   expiry_at = min(A, first_read_at + 24h)
if now >= expiry_at:
   deny_access(); remove_keys_and_caches(); purge_when_possible()
```

14.3 Synchronisation multi-appareils

- Un contrôle local compare l'horloge de référence et l'échéance ; l'heure locale seule ne doit pas permettre d'étendre artificiellement la durée.
- La première lecture est propagée entre appareils autorisés au moyen d'événements chiffrés ou authentifiés ; ne pas exposer la lecture à un serveur tiers sans nécessité.
- À la reconnexion, un appareil purge les éléments expirés avant affichage ; même hors ligne, l'application doit refuser un contenu dont le délai est dépassé.
- Les horloges décalées, déconnexions et conflits sont testés ; les erreurs favorisent la non-divulgation.

15 Sécurité, vie privée et conformité

15.1 Modèle de menace minimal

Menace	Contrôle requis
Interception réseau / serveur compromis	E2EE authentifié, clés locales, vérification d'identité, TLS en transport.
Usurpation d'identité	Empreintes cryptographiques, vérification QR, alerte changement de clé.
Vol d'appareil	Verrouillage, chiffrement local, effacement volontaire, gestion des sessions.
Captures / exfiltration	Réduction des prévisualisations et caches ; avertissement sur les limites.
Spam / traçage par recherche	Quotas, demandes de contact, blocage, absence de découverte par défaut.
Résurrection de données	TTL appliqué aux caches, sauvegardes, files et stockage objet ; tests de restauration.

15.2 Standards et obligations

- Adopter les contrôles adaptés de l'OWASP MASVS pour stockage, cryptographie, authentification, réseau et vie privée. [S7]
- Documenter l'analyse d'impact vie privée si nécessaire, le registre des traitements et les droits applicables dans les juridictions de déploiement.
- Si le RGPD s'applique, respecter notamment minimisation, limitation de conservation, intégrité et confidentialité. [S8]
- Prévoir audit de sécurité indépendant avant lancement public et revalidation lors des changements cryptographiques majeurs.

> **AUCUNE PROMESSE ABSOLUE**
>
> « Chiffré de bout en bout » ne signifie pas « impossible à surveiller, identifier ou capturer ». Les métadonnées, appareils compromis, copies externes et traces imposées par la loi doivent être traités de manière transparente.

16 Exigences non fonctionnelles

Catégorie	Objectif proposé pour validation
Performance UI	Viser 60 FPS sur appareils compatibles ; variante faible effets / sans flou.
Temps d'interaction	Navigation réactive ; instrumentation des temps sur appareils réels.
Réseau	Reconnexion après pertes courtes, répétition sans doublons, échec intelligible.
Disponibilité	Objectif de disponibilité backend à définir après dimensionnement ; pas de SLA implicite.

Catégorie	Objectif proposé pour validation
Batterie	Pas de réveils inutiles pour chaque message ; notifications regroupées et optimisées.
Stockage	Mesurer l'espace local, le nettoyage post-expiration et l'absence de sauvegardes privées.
Compatibilité	Version Android minimum et gamme matérielle déterminées après étude des appareils cibles.
Accessibilité	Libellés compréhensibles, tailles adaptatives, lecteur d'écran et réduction de mouvement.
Observabilité	Métriques de service sans texte, fichiers, secret cryptographique ni historique nominatif.

Qualité logicielle

Versionnement, intégration continue, tests automatiques, analyse des dépendances, revue de code, génération de versions reproductibles et plan de réponse aux incidents. Les dépendances cryptographiques seront surveillées et mises à jour de manière maîtrisée.

17 Plan de réalisation et livrables

Lot	Livrables	Critère de sortie
L0 - Conception	UX wireframes, modèles de menace, modèle de données, protocole d'expiration.	Arbitrages documentés et validés.
L1 - MVP (P0)	Comptes, contacts, chat E2EE, 3 modes, limite absolue, 4 alertes, UI GhOst.	Tests de sécurité fonctionnelle et scénarios d'expiration réussis.
L2 - Multimédia (P1)	Pièces jointes, groupes, appels, géolocalisation volontaire, mode Fantôme.	Tests de transport / permissions / charges.
L3 - Innovation (P2)	Filtres vocaux et vidéo, proximité hors ligne, identités secondaires.	Mesures d'appareils / vie privée / ergonomie.
L4 - Préproduction	Audit tiers, accessibilité, politique de rétention, tests de reprise et conformité.	Décision go / no-go explicitement documentée.

Livrables à produire par l'équipe

- Code source Android, backend et configurations d'infrastructure, tests et pipelines de livraison.
- Maquettes haute fidélité, design system et kit du logo validé ; icônes Android adaptées.
- Documentation cryptographique et modèle de menace, documentation API et procédures de gestion des clés.
- Politique de confidentialité, règles de traitement / suppression, gestion des signalements et des incidents.
- Rapport d'audit et procès-verbal de recette avant toute annonce de confidentialité certifiée.

18 Recette fonctionnelle et cas critiques

Test	Scénario	Résultat exigé
T01	Envoi 08:00, non lu	Inaccessible à J+1 08:00.
T02	Envoi 08:00, lecture 10:00, mode 15 min	Inaccessible à 10:15.
T03	Envoi 08:00, lecture J+1 07:55, mode 15 min	Inaccessible à J+1 08:00, pas à 08:10.
T04	Envoi 08:00, lecture J+1 07:00, mode 24 h	Inaccessible à J+1 08:00.
T05	Mode « À la lecture »	Impossible de rouvrir après fermeture de la première vue.
T06	Non lu à T+12 h / 21 h / 23 h / 23 h 45	Rappels possibles, silencieux et sans nom/contenu.
T07	Lecture après premier rappel	Tous rappels futurs de ce message annulés.
T08	Appareil hors ligne durant l'expiration	Aucun affichage autorisé après échéance ; purge à la reprise.
T09	Horloge système modifiée	Aucune prolongation indue du message.
T10	Redémarrage / restauration après expiration	Aucun contenu expiré ne redevient accessible.
T11	Fichier ou note vocale éphémère	Même politique que le message porteur ; cache purgé.
T12	Notification visible écran verrouillé	Pas de pseudo, expéditeur, aperçu ni pièce jointe.
T13	Destinataire bloqué / compte révoqué	Pas de livraison ni accès hors permissions.
T14	Destinataire offline pendant 24 h	Enveloppe relayée supprimée et non livrée ensuite.

Conditions d'acceptation globale

- Aucun échec des tests T01-T05, T08, T10 et T12 en recette de sécurité.
- Le serveur n'est pas capable de déchiffrer des contenus de messages lors des tests d'architecture.
- Des tests documentent les limites d'Android concernant les horaires effectifs des rappels.
- Les conditions de mise sur le marché sont revues par sécurité, produit et conformité.

19 Risques, arbitrages et questions ouvertes

Décision / risque	Position du cahier des charges
Disponibilité du nom GhOst	Nom validé comme identité produit ; recherche de disponibilité juridique et stores à réaliser avant publication.
Sans aucune base de données	Non retenu : un annuaire minimal et des préclés sont nécessaires pour l'usage attendu.
Messages hors ligne	Conservation chiffrée temporaire jusqu'à 24 h max, puis destruction / rejet de livraison.
Multi-appareils	Conception complémentaire et risques de cohérence à préciser avant activation.
Mode « À la lecture »	Première consultation terminée = expiration ; UX et fermeture forcée à tester.
30 min et 60 min	Non retenus dans les options actuellement validées ; seuls 3 modes restent.
Appels vidéo de groupe	À étudier ; coût de relais et modèle E2EE à confirmer.
Gamme Android / budget / échéancier	Non fournis ; étude de faisabilité et chiffrage nécessaires, aucune estimation inventée.
Droit des données	Évaluation selon juridictions et prestation juridique dédiée.

DÉCISION À TRANCHER AVANT LANCEMENT

Conserver un produit performant avec infrastructure limitée n'implique pas l'absence totale de serveurs. La priorité reste le chiffrement, l'effacement des messages et la minimisation prouvable des données.

20 Références techniques et juridiques

Sources primaires consultées pour distinguer les choix de conception des contraintes techniques. Les caractéristiques propres à GhOst sont des exigences du présent projet, pas des fonctionnalités attestées de ces sources.

[S1] Signal Foundation / Kret & Schmidt · 2024 (mise à jour)
PQXDH Key Agreement Protocol
https://signal.org/docs/specifications/pqxdh/

[S2] Signal Foundation / Perrin, Marlinspike & Schmidt · 4 nov. 2025
The Double Ratchet Algorithm, révision 4
https://signal.org/docs/specifications/doubleratchet/

[S3] IETF / Barnes et al. · juil. 2023 ; errata 2026
RFC 9420 - Messaging Layer Security
https://datatracker.ietf.org/doc/rfc9420/

[S4] WebRTC Project · documentation officielle
Getting started with peer connections (STUN/TURN)
https://webrtc.org/getting-started/peer-connections

[S5] Google / Android Developers · documentation consultée nov. 2026
Schedule alarms - restrictions et synchronisation

https://developer.android.com/develop/background-work/services/alarms

[S6] Google / Firebase · documentation consultée nov. 2026
Secure Your Message Data with End-to-End Encryption
https://firebase.google.com/docs/cloud-messaging/encryption

[S7] OWASP · documentation consultée nov. 2026
Mobile Application Security Verification Standard
https://mas.owasp.org/MASVS/03-Using_the_MASVS/

[S8] Parlement européen et Conseil de l'UE · 27 avr. 2016
Règlement (UE) 2016/679, notamment article 5
https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX%3A32016R0679

[S9] Google / Android Developers · documentation consultée nov. 2026
Blurring in Compose - performance et flou UI
https://developer.android.com/develop/ui/compose/graphics/blur/overview

21 Validation du cadrage

Ce document est une **spécification de référence** de la version 1.0. Il synthétise les choix de produit expressément établis et les propositions d'architecture à soumettre à un responsable technique, un spécialiste en sécurité et un designer mobile.

Statut	Éléments
Validé dans les échanges	Nom GhOst ; logo gris Liquid Glass ; priorité à la confidentialité ; 3 durées après lecture ; plafond envoi + 24 h ; quatre rappels silencieux et confidentiels.
Proposé pour mise en œuvre	Kotlin/Compose, WebRTC, protocoles E2EE, backend minimal, regroupement des rappels, plan de développement.
À arbitrer / auditer	Choix cryptographique final, multi-appareils, mode « À la lecture » exact, disponibilité du nom, dimensionnement, coûts, conformité et calendrier.

PRINCIPE DIRECTEUR

La sécurité d'une messagerie ne résulte pas d'un discours sur l'anonymat : elle doit être vérifiable par le code, les tests, la cryptographie, la gestion des clés, la minimisation des données et l'audit indépendant.

FIN DU CAHIER DES CHARGES · GhOst · Version 1.0 · 09/11/2026